AES Raptor Ultra CNC İşleme
IEC 62443 Mini Workshop
Kavramsal Çerçeve ve Makineye Özgü Uyarlama

Endüstriyel Otomasyon ve Kontrol Sistemleri (IACS) siber güvenlik standardı olan **IEC 62443** serisi, karmaşık siber-fiziksel sistemleri benzer kritiklik seviyesindeki güvenlik bölgelerine (*Zones*) ayırmayı ve bu bölgeler arasındaki her veri geçişini kontrollü, denetlenebilir kapılar (*Conduits*) üzerinden gerçekleştirmeyi şart koşar.

AES Group tarafından üretilen **Raptor Ultra (ve Raptor Ultra Line)** CNC işleme merkezi; fabrika yerel ağı (LAN) üzerinden CAD/CAM kesim listelerini alan, ERP/MES sistemleriyle barkod alışverişi yapan ve aynı zamanda 100 m/dk (1.67 m/sn) hızında ağır bir portal köprüyü ve 24.000 RPM iş milini yöneten bağlantılı bir makinedir. Bu nedenle (AB) 2023/1230 Makine Tüzüğü Ek III (Madde 1.1.9 ve 1.2.1) ile Siber Dayanıklılık Yasası (CRA - AB 2024/2847) kapsamında varlıkların sıkı bir bölgeleme mimarisine oturtulması zorunludur.

Görev A: Varlıkların Bölgelere (Zones) Ayrılması ve Conduit Tasarımı

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Laboratuvar föyünde yer alan 8 temel varlık, AES Raptor Ultra'nın gerçek donanım ve yazılım bileşenleriyle eşleştirilerek kritiklik ve Hedef Güvenlik Seviyelerine (*Target Security Level - SL-T*) göre 5 ayrı güvenlik bölgesine ayrılmıştır:

- **Bölge 1: Kurumsal Ofis ve Fabrika IT Bölgesi (Enterprise IT Zone — SL-T 1)**
- **Ofis Ağı (ERP / E-posta):** Müşteri siparişlerinin alındığı, plaka stoklarının tutulduğu, kurumsal e-posta ve ERP sistemlerinin çalıştığı fabrika bilgi teknolojileri ağı.
- **Bölge 2: Endüstriyel DMZ ve Uzak Erişim Bölgesi (Industrial DMZ Zone — SL-T 3)**
- **Uzak Servis Erişimi (Remote Diagnostics / Jump Server):** AES Group teknik servis mühendislerinin arıza teşhisi, bellenim (firmware) güncellemesi ve parametre kontrolü için dış ağdan bağlandığı yalıtılmış tampon bölge (Bastion Host / Jump Server). IT ağı ile OT ağı arasında doğrudan trafiği engelleyen arındırılmış bölgedir.
- **Bölge 3: Üretim Planlama, CAD/CAM ve Operasyonel İzleme Bölgesi (Site Operations & MES Zone — SL-T 2)**
- **Mühendislik İstasyonu:** *NC Hops*, *Alphacam (Standard/Advanced)* ve *Cabinet Vision* yazılımlarının çalıştığı; .DXF, .STL, .STEP formatındaki 3D katı modellerin işlenip çarpışma kontrolü (collision control) yapıldıktan sonra G-kodlarının ve kesim listelerinin üretildiği tasarım istasyonu.
- **SCADA İstemcisi (MES / Cadmus Üretim Takip İstemcisi):** Makinenin çalışma durumunu, vardiya verimliliğini (OEE), kesilen plaka sayılarını ve hata mesajlarını izleyen merkezi üretim takip ve görselleştirme istemcisi.
- **Bölge 4: Makine Hücre Kontrol ve Operatör Bölgesi (OT Cell Control Zone — SL-T 3)**
- **HMI (İnsan-Makine Arayüzü):** Mobil kontrol konsolu üzerindeki 21 inç (veya 17 inç) endüstriyel dokunmatik ekran, otomatik hatlardaki *Label X* barkod etiketleme istasyonu ekranı, kablolu

Handterminal Pro el çarkı ve entegre barkod okuyuculu kablosuz *Handterminal Pro+* kontrol arayüzü.

- **Robot Kontrolörü (CNC Hareket ve Sürücü Kontrolcüsü):** İtalyan menşeli PC tabanlı *OSAI (Series 10/510i / OPENcontrol)* veya *Syntec 6MA* ana CNC kontrol ünitesi, 5 eksenli kafa / C ekseni interpolasyon ünitesi, *Panasonic* kapalı çevrim dijital AC servo sürücüler, *HSD* ($9–14$ kW) VFD frekans invertörü ve otomatik yükleme/hizalama robotu kontrolcüsü.
- **Normal PLC:** Yardımcı makine fonksiyonlarını yürüten **AES PLC** ünitesi (12/16'lı ve 10'lu döner ATC takım değiştirme magazini, *Vacuboost* 8–18 bölgeli akıllı vakum valfleri, *Becker* vakum pompaları, merkezi toz emiş pnömatik klapeleri, 21 noktalı otomatik merkezi yağlama ve konveyör/lift senkronizasyonu).
- **Bölge 5: Fonksiyonel Emniyet Bölgesi (OT Safety Zone / SRP/CS — SL-T 4)**
- **Safety PLC (Emniyet Kontrol Sistemi ve Röle Grubu):** EN ISO 13849-1 (PL d/PL e) standartlarına sahip çift kanallı emniyet PLC'si / emniyet röleleri, dikey/yatay emniyet ışık perdeleri, lazer alan tarayıcı (*Area Scanner*), basınca duyarlı emniyet paspasları (*contact mats*), portal eteklerindeki çarpışma tamponları (*pressure cushions*), mantar başlı E-Stop butonları, *HandterminalPro+* kablosuz sinyal kesintisi emniyet rölesi, 5 Bar pnömatik basınç/vakum kaybı şalterleri, HSK-F63 iş mili 0 RPM kilit sensörleri ve servo sürücülerin donanımsal STO (*Safe Torque Off*) girişleri.

2. Safety PLC'yi hangi bölgeye koydunuz ve neden?

Safety PLC ve ona bağlı tüm elektro-duyarlı koruma ekipmanları (ESPE), mimarideki en yüksek güvenlik seviyesi olan **Bölge 5: Fonksiyonel Emniyet Bölgesi (OT Safety Zone — SL-T 4)** içerisine yerleştirilmiş ve diğer tüm bölgelerden mantıksal ve fiziksel olarak izole edilmiştir. **Mühendislik ve Yasal Gerekçesi:**

1. **Yüksek Kinetik Enerji ve Fiziksel Risk:** Raptor Ultra'da yaklaşık $800–1200$ kg kütleye sahip portal köprü 100 m/dk hızla hareket etmekte ve HSD iş mili 24.000 RPM hızla dönmektedir. Tehlike anında sistemin maksimum $t_2 = 250$ ms içinde durması (Safe Stop) ve iş mili durmadan pensin açılmaması hayati önem taşır.
2. **Yozlaşmaya Karşı Koruma ((AB) 2023/1230 Ek III Madde 1.1.9):** Yeni Makine Tüzüğü uyarınca, ağa bağlı bir cihaz üzerinden gelen kasıtlı veya kazara bir siber müdahale, emniyet fonksiyonlarını bozmamalıdır. Eğer Safety PLC, Windows/PC tabanlı HMI veya standart AES PLC ile aynı düz ağda (flat network) bulunursa; .DXF kesim dosyası veya USB üzerinden sızan bir zararlı yazılım, emniyet belleğindeki *ışık perdesi bypass bitlerini*, *yazılımsal limit şalterlerini* veya *hız sınırlarını* değiştirebilir.
3. **Kötü Niyetli Müdahale ve DoS Dayanımı (Ek III Madde 1.2.1):** CNC kontrol ünitesinin ağ arayüzüne Hizmet Reddi (DoS/DDoS) veya bellek taşması (*buffer overflow*) saldırısı yapılsa ve HMI ekranı tamamen kilitlense dahi, izole edilmiş Safety Zone bu trafikten etkilenmez; deterministik döngüsünü (< 30 ms tepki süresi) koruyarak makineyi güvenli duruşa geçirir.

3. Bölgeler arası geçişler (Conduit) nerede? Her geçişte ne kontrol edilecek?

Bölgeler arasındaki her veri yolu bir **Conduit(VeriKanalı)** olarak tanımlanmış ve güvenlik duvarı (Firewall), derin paket inceleme (DPI) ve erişim kontrol kurallarıyla sınırlandırılmıştır:

Conduit Kodu		Bağlanan Bölgeler	Geçişte Kontrol Edilecek Unsurlar ve Güvenlik Kuralları
Conduit (C1)	**1**	Dış Ağ / İnternet ↔ Bölge 2 (Endüstriyel DMZ)	**Uzak Servis Geçişi:** Doğrudan OT erişimi yasaktır. Yalnızca TLS 1.3 / IPsec VPN tüneli, Çok Faktörlü Kimlik Doğrulama (MFA) ve kişisel sertifikalar kontrol edilir. Tüm trafik Jump Server üzerinde sonlandırılır.
Conduit (C2)	**2**	Bölge 1 (Ofis IT / ERP) ↔ Bölge 2 (DMZ) ↔ Bölge 3 (MES / CADCAM)	**IT/OT Sınır Geçişi:** Kurumsal ağdan üretim katmanına doğrudan geçiş engellenir. Yalnızca doğrulanmış üretim iş emirleri, barkod verileri ve .DXF/.STEP tasarım dosyalarının geçişine izin verilir. Dosyalar antivirüs/sandbox taramasından ve bütünlük (hash) kontrolünden geçirilir; e-posta ve genel internet trafiği bloklanır.
Conduit (C3)	**3**	Bölge 2 (DMZ Jump Server) → Bölge 4 (OT Hücre Kontrol)	**Kontrollü Bakım Kanalı:** Varsayılan olarak kapalıdır (*Default Deny*). Yalnızca sahadaki operatörün 21 inç HMI üzerinden verdiği onay ile açılır. Yüklenen OSAI/Syntec veya AES PLC bellenimlerinin dijital imzası (**Secure Boot**) doğrulanır ve tüm oturum 5 yıllık *Tracing Log* kapsamında kaydedilir.
Conduit (C4)	**4**	Bölge 3 (Mühendislik / SCADA) ↔ Bölge 4 (OT Hücre Kontrol)	**Üretim ve Telemetri Kanalı:** Mühendislik istasyonundan CNC'ye yalnızca G-kodu/kesim programı yüklenebilir (RBAC kontrolü). SCADA/MES istemcisine doğru ise yalnızca durum ve telemetri verisi (OPC UA / okuma yönlü) akar. Hız sınırı (100 m/dk) gibi kritik PLC parametrelerine yetkisiz yazma (*write*) komutları endüstriyel güvenlik duvarı (DPI) ile engellenir; hız sınırlama (*rate limiting*) ile DoS koruması uygulanır.
Conduit (C5)	**5**	Bölge 4 (OT Hücre Kontrol) ← Bölge 5 (OT Safety Zone)	**Emniyet İzolasyon Kanalı (Tek Yönlü / Salt Okunur):** En kritik geçiş noktasıdır. Bölge 5'ten Bölge 4'e (HMI ve Normal PLC'ye) yalnızca **salt okunur (readonly)** teşhis bilgisi (ör. "Işık perdesi kesildi", "Hava basıncı < 5 Bar", "Acil Stop basıldı") aktarılır. Bölge 4'ten Bölge 5'e doğru ağ üzerinden hiçbir parametre yazma veya emniyet köprüleme (*bypass/override*) komutu geçemez. Fiziksel durdurma sinyalleri (STO) doğrudan donanımsal çift kanal üzerinden sürücülere iletilir.

Tablo 1: AES Raptor Ultra IEC 62443 Conduit (Veri Kanalı) Kontrol Matrisi

Görev B: Uzak Erişim Kararı (Remote Access Architecture)

AES Raptor Ultra üzerinde uzaktan teşhis (*remote diagnostics*), arıza analizi ve yazılım güncelleme süreçleri için IEC 62443-3-3, (AB) 2023/1230 Makine Tüzüğü ve Siber Dayanıklılık Yasası (CRA) gerekliliklerine göre alınan 6 temel mimari karar aşağıda detaylandırılmıştır:

KararBaşlığı	Seçenekler	Seçiminiz ve Mühendislik / Regülasyon Gerekçesi
1. Aracı?	Doğrudan / Jump server	**Seçim: Jump Server (Endüstriyel DMZ Bastion Host).** **Neden:** Dış ağdan OSAI/Syntec kontrolcüye veya AES PLC'ye doğrudan (*direct*) bağlantı kurulması, dış tehditleri doğrudan OT kontrol katmanına taşır. DMZ bölgesindeki bir Jump Server aracılığıyla ağ protokolü kırılır (*protocol break*), dosya transferleri taranır ve makine kontrol ağına doğrudan IP erişimi izole edilir.
2. Tünel?	Açık / VPN	**Seçim: VPN (Şifreli Kriptografik Tünel — IPsec / TLS 1.3).** **Neden:** Kesim programları, PLC parametreleri veya teşhis paketleri açık ağ üzerinden gönderildiğinde ortadaki adam (*MitM*) ve paket enjeksiyonu saldırılarıyla değiştirilebilir. Makine Tüzüğü Ek III Madde 1.1.9 (Yozlaşmaya Karşı Koruma) gereği veri bütünlüğü ve gizliliği sertifika tabanlı VPN tüneli ile korunmalıdır.
3. Kimlik?	Parola / MFA	**Seçim: MFA(ÇokFaktörlüKimlikDoğrulama+RBAC). Neden:** Statik parolalar kimlik avı (*phishing*) veya kaba kuvvet saldırılarıyla kolayca ele geçirilebilir. Uzaktan bağlanan servis mühendisinin kimliği donanım anahtarı veya tek kullanımlık şifre içeren MFA ile doğrulanmalı ve Rol Tabanlı Erişim Kontrolü (RBAC) ile yalnızca yetkili olduğu alt sisteme erişebilmelidir.
4. Hesap?	Paylaşılan / Kişisel	**Seçim: Kişisel (Bireysel ve İsimlendirilmiş Hesaplar). Neden:** "admin" veya "service" gibi paylaşılan hesaplar kullanıldığında, makine parametrelerinde yapılan hatalı veya kötü niyetli bir değişikliğin (örneğin eksen hız limitlerinin değiştirilmesi) kimin tarafından yapıldığı tespit edilemez. İnkâr edilemezlik (*non-repudiation*) ilkesi gereği her uzmana kişisel hesap tanımlanmalıdır.
5. Kayıt?	Yok / Tam oturum kaydı	**Seçim: Tam Oturum Kaydı (Audit / Tracing Log).** **Neden:** (AB) 2023/1230 Makine Tüzüğü Ek III Madde 1.1.9 ve 1.2.1 uyarınca, makine kontrol yazılımına yapılan tüm meşru ve gayrimeşru müdahaleler ile yüklenen güvenlik yazılımı versiyonları zaman damgalı kayıt defterinde (*Tracing Log*) tutulmalı ve piyasaya arzdan itibaren **5 yıl boyunca** denetim makamlarına sunulabilmelidir. Ayrıca CRA Madde 14 kapsamındaki 24 saat (Erken Uyarı) ve 72 saat (Detaylı Bildirim) yükümlülüklerinde kök neden analizi yapabilmek için tam oturum kaydı şarttır.

6.	**Zamanlama?**	Sürekli açık / Varsayılan kapalı	**Seçim: Varsayılan Kapalı (Default Deny / Operatör Onaylı).** **Neden:** Sürekli açık bırakılan bir uzak erişim kanalı makineyi 7/24 siber taramalara ve sıfırıncı gün (*zero-day*) saldırılarına maruz bırakır. Uzak erişim portu varsayılan olarak kapalı olmalı; yalnızca bakım gerektiğinde sahadaki operatörün 21 inç HMI konsolu üzerinden fiziksel/dijital onayıyla (*request-to-connect*) açılmalı ve işlem bitiminde otomatik zaman aşımı (*time-out*) ile kapanmalıdır (CRA *Security by Default* ilkesi).

Tablo 2: Görev B: AES Raptor Ultra Uzak Servis Erişimi Mimari Karar Tablosu

Kaynakça

1. **AES Group Raptor Ultra Teknik Analiz Raporu**: CE Uygunluk Değerlendirmesi İçin Tersine Mühendislik Tabanlı Kör Analiz ve Laboratuvar Doğrulama Raporu (Kontrol, Sürücü, Yazılım ve Siber-Fiziksel Sistem Mimarisi & 4. Laboratuvar Uygulaması).
2. **Endüstriyel Siber Güvenlik Standartları**: IEC 62443-3-2 (Güvenlik Risk Değerlendirmesi, Sistem Tasarımı - Zones & Conduits), IEC 62443-3-3 (Sistem Güvenlik Gereklilikleri ve Güvenlik Seviyeleri) ve IEC 62443-4-2 (IACS Bileşenleri İçin Teknik Güvenlik Gereklilikleri).
3. **Yeni Makine Tüzüğü**: Avrupa Birliği (AB) 2023/1230 Makine Tüzüğü, Ek III Madde 1.1.9 (Yozlaşmaya Karşı Koruma) ve Madde 1.2.1 (Kontrol Sistemlerinin Güvenliği, Güvenilirliği ve 5 Yıllık Yazılım İzleme Kaydı / Tracing Log Zorunluluğu).
4. **Siber Dayanıklılık Yasası (CRA)**: Avrupa Birliği (AB) 2024/2847 Yönetmeliği, Madde 14 (11 Eylül 2026 itibarıyla 24/72 Saatlik Zafiyet ve Olay Raporlama Yükümlülüğü) ve Ek I (Tasarımda ve Varsayılanda Güvenlik Gereklilikleri).

Fonksiyonel ve Makine Emniyeti Standartları: EN ISO 19085-3:2021 (NC/CNC delik ve freze makineleri güvenliği) ve EN ISO 13849-1 (Kontrol sistemlerinin güvenlikle ilgili kısımları - SRP/CS).